SOC THREAT HUNTING & STATIC MALWARE ANALYSIS REPORT

PhantomRing Investigation Report

Static Dissection of a Stealthy Linux Post-Exploitation Agent

1. Document Control & Author

Field	Details
Author	Jonathan Di Genova (Junior SOC Analyst & Cybersecurity Specialist)
Date	November 12, 2026
Case Reference	Hack The Box Sherlock — PhantomRing (Category: Malware Analysis | Difficulty: Very Easy)
Target Artifact	Protected archive `PhantomRing.zip` containing ELF executable `agent`
Classification	Personal Study Document / Blue Team Technical Portfolio

2. Case Overview & Scope

During a proactive threat hunting operation on a monitored Linux server, the Security Operations Center (SOC) intercepted a suspicious executable located inside `/var/tmp`. The binary bore an unusual filename and was actively attempting to initiate outbound network communications. Preliminary triage indicated that the artifact operated as a lightweight post-exploitation agent.

The objective of this static analysis engagement is to safely inspect the recovered ELF binary within an isolated Kali Linux environment—without executing it—to determine its functional capabilities, extract network Indicators of Compromise (IOCs), map out its internal command architecture, and document the advanced kernel-level evasion and anti-forensic mechanisms employed by the threat actor.

> **Analytical Methodology Note:** In accordance with platform ethics and responsible disclosure guidelines, raw flag values, exact cryptographic hashes, and direct task answers are abstracted into technical artifact descriptions to focus on investigative methodology and defensive engineering.

3. Personal Investigation Timeline

The investigation followed a structured four-phase Blue Team static triage workflow, transitioning from high-level string extraction to targeted assembly inspection:

Phase	Tools & Commands	Analytical Objective & Outcome
Phase 1: Artifact Acquisition & Integrity	`unzip`, `sha256sum`	Extracted the binary from the encrypted container and generated a unique cryptographic fingerprint to establish sample identity. **(Task 1: Completed)**
Phase 2: Network & C2 Triage	`strings`, `grep`, `objdump`	Isolated hardcoded IPv4 patterns, inspected `htons@plt` assembly instructions to decode integer-stored listener ports, and analyzed `sleep@plt` arguments to determine beacon retry intervals. **(Tasks 2–4: Completed)**
Phase 3: Capability & Command Mapping	`strings`, `objdump`	Enumerated internal symbol tables (`cmd_*` routines) to distinguish core agent capabilities from auxiliary usage strings, confirming 11 distinct operational commands. **(Task 5: Completed)**
Phase 4: Evasion & Anti-Forensics	`strings`, `grep`, Linux Internals	Identified kernel interface abuse for syscall evasion, active defense-blinding routines against eBPF and kernel tracing, and self-deletion logic. **(Tasks 6–12: Completed)**

4. Key Evidence & Technical Artifacts

4.1 Command & Control (C2) Configuration

Static string filtering revealed a single hardcoded private IPv4 address used as the C2 destination. Because the destination port and reconnection delay were compiled as integer constants rather than ASCII text, disassembling the binary in Intel syntax (`objdump -d -M intel`) was required. Inspecting register assignments immediately preceding `htons@plt` and `sleep@plt` calls revealed the hexadecimal port number and the fixed backoff interval in seconds.

4.2 Host Reconnaissance & Privilege Escalation

- **Session Accounting Enumeration:** Within the user enumeration routine, the agent directly parses the active session accounting file under `/var/run/` rather than spawning noisy child processes such as `who` or `w`.
- **SUID Binary Discovery:** During privilege escalation checks, the malware systematically scans standard system binary directories (specifically targeting `/usr/bin`) to identify executables configured with the Set User ID (SUID) bit.

4.3 EDR Evasion & Defense Blinding

- **Asynchronous Syscall Evasion:** Rather than relying on traditional synchronous I/O system calls (such as `read`, `write`, or `connect`) heavily monitored by user-space and kernel EDR hooks, the agent abuses the modern Linux `io_uring` asynchronous ring-buffer interface.
- **eBPF Security Tool Termination:** The agent iterates through process memory mappings via `/proc/[pid]/maps`, searching for anonymous inode descriptors associated with BPF memory maps to identify and terminate active eBPF-based monitoring agents.

- **Kernel Tracing Sabotage:** Prior to executing sensitive operations, the malware attempts to blind kernel-level telemetry by writing disable flags directly to `debugfs` / `tracefs` control files (starting with the global `tracing_on` switch).

4.4 Anti-Forensic Self-Destruction

Upon receiving a specific abbreviated self-destruct command string from the C2 operator, the agent queries the virtual filesystem link `/proc/self/exe` to resolve its own absolute path on disk and unlinks the binary prior to process exit, minimizing residual forensic evidence.

5. Lessons Learned & Hardening Recommendations

Defensive Takeaway: Analyzing PhantomRing demonstrates how modern Linux post-exploitation frameworks exploit legitimate, high-performance kernel subsystems (`io_uring`) to bypass legacy syscall auditing, while simultaneously targeting defensive telemetry (eBPF maps and `ftrace`). Relying exclusively on string extraction is insufficient when numeric constants are embedded in assembly instructions.

- **Kernel-Aware Runtime Monitoring:** Deploy modern eBPF security sensors (e.g., Tetragon or Falco) configured to monitor `io_uring` submission queue entries (SQEs) and anomalous process access to `/proc/[pid]/maps` .
- **Restrict Kernel Debugging Interfaces:** Harden production Linux servers by restricting access to `/sys/kernel/debug/tracing` via strict mount permissions and enabling Linux kernel lockdown mode where operationally feasible.
- **Filesystem & Execution Controls:** Mount volatile directories such as `/var/tmp` and `/dev/shm` with the `noexec` option to prevent unauthorized binaries from executing out of world-writable staging locations.